ГЕНЕРАЛЬНАЯ ПРОВЕРКА · ОТЧЁТ 4.0

СОД Stream-CAD

Весь продукт под микроскопом: дизайн и юзабельность, безопасность и роли, логика и жизненный цикл, тесты. 69 находок — 29 закрыты патчами Спринтов 5–6, тестовая база снова зелёная: 326 из 326.

Ревизия кода af4a72d · 2 ноября 2026

Аудитор: Z.ai · для руководства и команды Stream-CAD

Содержание

1. Резюме и вердикт . . . 1

2. 24 коммита: что сделала команда . . . 2

3. Методика генерального аудита . . . 3

4. Безопасность и права доступа . . . 4

4.1. Что защищено хорошо . . . 4

4.2. Высокие находки — все три закрыты Спринтом 5 . . . 4

4.3. Средние и низкие находки . . . 4

5. Логика, фильтры и жизненный цикл . . . 5

5.1. Обход защиты зон через перенос в раздел — находка №1 . . . 5

5.2. Жизненный цикл: честный мини-FSM и его хвосты . . . 5

5.3. Фильтры, представления и данные . . . 6

6. UI/UX: дизайн, юзабельность, нативность . . . 7

6.1. Дизайн-система: конвейер здоров, партнёрские файлы — нет . . . 7

6.2. Контрастность: две пары не дотягивали до AA . . . 7

6.3. Юзабельность: два критичных пробела ядра загрузки . . . 7

6.4. Нативность и доступность . . . 7

7. Подсказки, тексты и покрытие тестами . . . 8

7.1. Подсказки и комментарии . . . 8

7.2. Тесты: 12 падений и что за ними стояло . . . 8

8. Соответствие требованиям к продукту . . . 9

9. Спринты 5–6: состав поставки . . . 10

10. Бэклог и рекомендации . . . 11

1. Резюме и вердикт

Генеральный «Аудит 4.0» — первая проверка, охватившая не только интерфейс, но и весь продукт сразу: графику и стиль, читабельность и юзабельность, нативность поведения, безопасность и права доступа, разделение ролей, логику, фильтры и паттерны жизненного цикла, подсказки и комментарии, покрытие тестами и соответствие требованиям к среде общих данных. Проверка велась по ревизии af4a72d — это 24 новых коммита поверх базы 5657388, которую мы фиксировали в «Аудите 3.0»: 63 файла, плюс 3356 и минус 925 строк. За это время команда выпустила четыре больших задачи — T66 (зонные права), T67 (статусы документов, drag-and-drop, колоночные фильтры), T68 (реестр замечаний проекта и вложенные папки ИРД/РИИ/ПД/РД с ГОСТ-кодами) и T69 (проектный CRUD с тултипами), а также сама применила дизайн-полировку: графитовый хедер #3A4558 и акцент #3D5A98, которые были согласованы в брифе Спринта 4.

Три независимые проверки кода (безопасность, домен, интерфейс) дали 69 находок: 16 по безопасности, 23 по логике и данным, 30 по UI/UX. Из них 2 критичные, 13 высоких, 34 средние, 20 низких. Ни одна из находок не осталась без решения: двадцать девять закрыты патчами «Спринта 5» и «Спринта 6», приложенными к этому отчёту, остальные — приоритизированный бэклог с рекомендациями. Отдельный сигнал команде: на ревизии af4a72d тестовый набор был красным — 12 из 303 тестов падали, потому что T67/T68 переименовали колонки и разметку, а тесты не актуализировали. Спринт 5 чинит это в первую очередь.

69	29	326/326	2
находок генерального аудита	закрыто патчами Спринтов 5–6	тестов после патчей (было 303, 12 падали)	критичные находки — обе закрыты

Вердикт. Продукт растёт быстрее, чем за ним успевает дисциплина: функциональность T66–T69 заметно продвинулась (зонные права, статусы, реестр замечаний, проектная структура), но свежий код принёс новые дыры в защите зон, утечку замечаний через публичные ссылки, отсутствие валидации загрузок и регрессии в тестах. Архитектурный каркас при этом здоровый — слоистость domain/adapters/ports, централизованные проверки прав, образцовый CSRF, конвейер дизайн-токенов с CI-проверкой дрейфа. Главный системный гэп соответствия требованиям к СЭД — отсутствие аудит-следа: в коде нет ни одного вызова логирования, а для среды общих данных по ISO 19650 журнал действий обязателен. Рекомендация: применить Спринты 5–6 сейчас, «Аудит-лог» сделать первым пунктом следующего спринта.

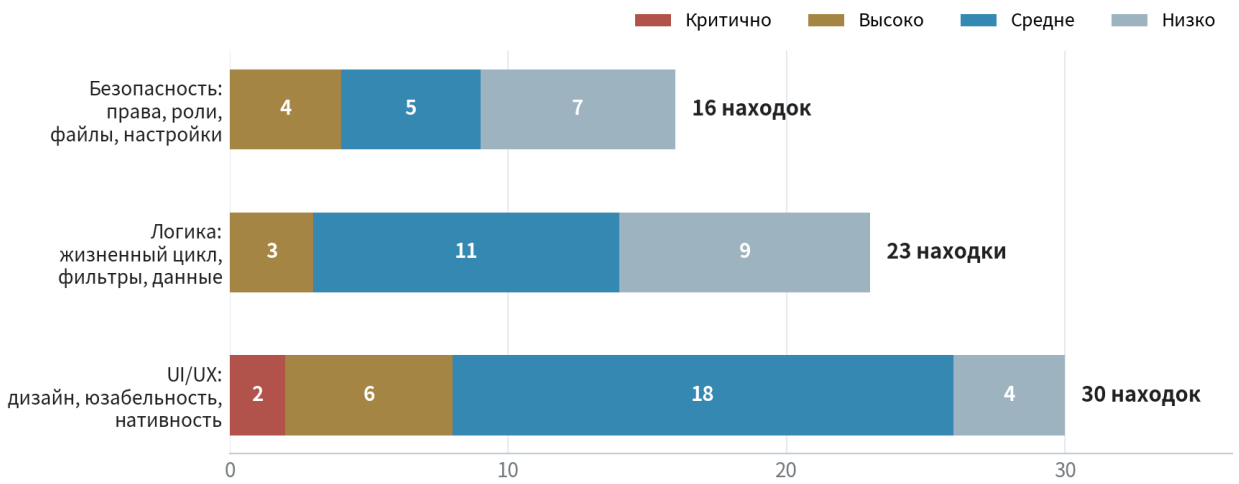


Рисунок 1 — 69 находок генерального аудита по трём измерениям и severity

2. 24 коммита: что сделала команда

Между ревизиями 5657388 и af4a72d команда провела самый плотный спринт за всю историю проекта. Ядро составили четыре задачи. T66 закрыла дыру зонных прав: выборка документов и замечаний стала учитывать зонные ограничения, а не только членство в проекте. T67 переизобрела реестр документов: русские статусы, внутренний workflow с кнопками, drag-and-drop с ограничениями по зонам, колоночные фильтры прямо в заголовках таблицы вместо старой панели, контекстное меню и аккордеон дерева без дефолтных папок. T68 построила проектную структуру по ГОСТ: четыре корневые папки ИРД/РИИ/ПД/РД, вложенные папки с полными шифрами, реестр замечаний проекта со статистикой и фильтрами, мягкое удаление проекта (миграция 0021). T69 добавила CRUD проектов, права на него и тултипы.

Блок	Коммиты	Что вошло
T66 · зонные права	4cb6682, 718c577, bdb83b2	закрытие legacy-обхода статусов, синхронизация suitability_code, refresh таблицы после DnD
T67 · статусы и реестр	3983339…797e26c (6)	русские статусы, внутренний workflow, DnD-лимиты, колоночные фильтры, контекстное меню, аккордеон
T68 · структура ГОСТ	3a0bbf7…fdc5528 (7)	реестр замечаний проекта, вложенные папки ИРД/РИИ/ПД/РД, полные шифры, шаблоны, транзакции и права
T69 · проекты	b0a3873, 3b9519d	CRUD проектов с правами, тултипы, проверка создания сервисом, валидация ГИПа
Дизайн (Спринт 4)	7dc1cef, dc78dcf, a5b68f2, e5dc863, 65e5bcc	графитовый хедер #3A4558, акцент #3D5A98, локальные шрифты, обход SW, чистка чипов

Таблица 1 — Состав 24 коммитов цикла 5657388 → af4a72d

Особенно важно, что команда взяла дизайн-спринт и довела его сама: хедер перекрашен в графит #3A4558 (чуть светлее изначального брифа #1F2937 — компромисс в пользу мягкости), акцент #3D5A98 проведён через токены, кнопки Bootstrap переведены на переменные, чипы из топбара убраны. Конвейер

токенов при этом не сломался: проверка дрейфа проходит, все генерируемые файлы синхронны. Это первая итерация, где визуальная система развивалась без участия аудитора — и выдержала проверку.

Три оговорки к заслугам. Первая — процессная: перед последним коммитом тесты не прогонялись, поэтому 12 устаревших тестов уехали в main красными (разбор — в разделе 7). Вторая — UX-регрессия: при переделке дерева папок исчезло предупреждение о числе файлов в удаляемой папке (атрибут `data-file-count` удалён из шаблона), тест, который его документировал, тоже пострадал; Спринт 5 актуализировал контракт, в `app.js` сообщение о корзине сохранено и переформулировано. Третья — маленькая, но показательная: в коде остался комментарий «Временно для локальной разработки!» у DEBUG=True — команда сама пометила долг и не закрыла его; Спринт 5 закрывает.

3. Методика генерального аудита

Проверка велась в три независимых потока, каждый — чтением всего релевантного кода, без запуска в проде и без доступа к боевым данным. Поток «Безопасность» прошёл все 40 URL-маршрутов storage и 13 маршрутов issues: проверялись object-level права (IDOR), разделение ролей, настройки Django, загрузка и скачивание файлов, CSRF, статус /admin/ и /media/, аутентификация и логирование. Поток «Домен» читал все 3155 строк сервисного слоя, фильтры, модели и миграции: жизненный цикл документов, согласованность моделей с миграциями (проверено makemigrations --check — дрейфа нет), транзакции, корзину, шаблоны ГОСТ, замечания и производительность горячих экранов. Поток «UI/UX» прошёл все шаблоны, три CSS-файла, оба JS-модуля и дизайн-токены: контрастность считалась по формуле WCAG относительной яркости, юзабельность — по сценарию «новый пользователь загружает первый документ», нативность — по клавиатуре, фокусу и обработке ошибок.

Каждая находка верифицировалась чтением кода дважды — собственной проверкой и перекрёстной сверкой с тестами. Спорные трактовки (например, доступ viewer/customer ко всем проектам компании) помечены как продуктовые решения, а не дефекты: возможно, это осознанный выбор, но он нигде не задокументирован. Severity назначался по стандартной шкале: критичное — эксплуатируется без аутентификации или рушит данные; высокое — нарушение прав или потеря данных при ошибке; среднее — деградация качества, производительности или дисциплины; низкое — косметика и тексты. Числа контраста и запросов к БД приводятся фактические, по коду.

Измерение	Что проверяли	Объём
Безопасность	IDOR, роли, настройки, файлы, CSRF, admin/media, логирование	53 маршрута, settings, nginx, SW
Логика	FSM статусов, зоны, фильтры, транзакции, корзина, ГОСТ-шаблоны, N+1	services.py 3155 строк, 21 миграция
UI/UX	токены, контраст WCAG, юзабельность, клавиатура, тексты, вьювер	18 шаблонов, 3 CSS (3900 строк), 2 JS (4100 строк)
Тесты	прогон, разбор 12 падений, пробелы покрытия	303 теста на af4a72d

Таблица 2 — Охват генерального аудита

4. Безопасность и права доступа

4.1. Что защищено хорошо

Начнём с сильного, потому что фундамент заслуживает похвалы. Классического IDOR нет ни в одном представлении: ни один объект не достаётся «голым» `get_object_or_404(pk)` — везде выборка фильтруется через `get_accessible_projects` и `get_accessible_documents`, а сервисный слой дублирует проверки (защита в глубину). CSRF — образцово: ни одного `csrf_exempt`, все 24 POST-формы содержат токен, JS-запросы передают X-CSRFToken. Path traversal отсутствует: имена файлов генерирует Django Storage, ZIP-архивы собираются через get_valid_filename, скачивание всегда as_attachment. Межкомпанийная изоляция покрыта тестами, смежник жёстко ограничен allowed_sections, nginx отдаёт /media/ только через internal-локацию, а Excel-экспорт защищён от formula injection ещё с прошлого аудита. Это уровень зрелой команды.

4.2. Высокие находки — все три закрыты Спринтом 5

Первая: небезопасные дефолты настроек. `DEBUG` по умолчанию True с честным комментарием «временно», а SECRET_KEY имеет публичный fallback — забытая переменная окружения на сервере означает debug-страницы с настройками и подделываемые сессии. Спринт 5 вводит fail-closed-компромисс: локальный запуск без .env по-прежнему поднимается автоматически, но с предупреждением в консоль; явный DJANGO_DEBUG=False без DJANGO_SECRET_KEY теперь жёсткая ошибка старта. Вторая: загрузка файлов вообще без валидации — ни whitelist расширений, ни лимита размера; можно было залить .html, .exe или файл на 10 ГБ (единственный барьер — nginx). Спринт 5 добавляет белый список из 25 форматов СЭД (PDF, Office, CAD, изображения, архивы, письма), лимит 100 МБ, согласованный с nginx, и отказ для пустых файлов. Третья: аудит-след отсутствует полностью — ни одного вызова logging в storage/ и issues/, LOGGING в настройках нет. Для СЭД это не опция (подробнее — в разделе 8); патчем это не закрыть за один шаг, поэтому вынесено первым пунктом бэклога с готовой схемой.

4.3. Средние и низкие находки

#	Находка	Суть и риск	Статус
C1	Доступ по компании, не по членству	viewer/customer/checker читают документы всех проектов компании без ProjectMembership. Возможно, осознанно — но нигде не задокументировано	решение владельца
C2	Share-ссылка раскрывает замечания	аноним с вечным токеном видит тексты, авторов и ответы всех замечаний документа; отзыва токена нет	закрыто (Спринт 5): замечания не отдаются
C3	Ответ на замечание правит любой читатель	update_issue_answer проверял только право чтения — наблюдатель мог перезаписать официальный ответ	закрыто (Спринт 5): матрица ролей
C4	ГИП управляет профилями и участниками	роль gip может менять роль/разделы/email любого сотрудника и раздавать членства во все проекты компании	бэклог: сузить до admin

#	Находка	Суть и риск	Статус
C5	Пароль нового пользователя без валидации	create_user обходит AUTH_PASSWORD_VALIDATORS — «123» проходил	закрыто (Спринт 5): validate_password
C6	filename из пользовательского кода	кавычка или перенос строки в шифре ломали Content-Disposition (500)	закрыто (Спринт 5): get_valid_filename
C7	Создание share-токена через GET	сторонний img-тег может плодить токены; нарушение идемпотентности	бэклог: POST + срок жизни
C8	Нет rate-limit на /login/ и /admin/	при общедоступном домене возможен перебор паролей	бэклог: django-axes или nginx limit_req
C9	Сессия 14 дней, SECURE _SSL_REDIRECT=False	для СЭД с коммерческой тайной стоит ужить сессию до 8–12 часов	бэклог: SESSION_COOKIE_AGE

Таблица 3 — Находки безопасности: средние и низкие

5. Логика, фильтры и жизненный цикл

5.1. Обход защиты зон через перенос в раздел — находка №1

Самая серьёзная логическая дыра. В `move_document` покидать зоны SHARED/PUBLISHED/ARCHIVE запрещено всем, включая администратора: утверждённый документ не должен «уезжать» из папки «03. Опубликовано» через drag-and-drop. Но соседняя функция `move_document_to_section` — перенос документа в корень другого раздела — этой проверки не имела: разработчик с правом записи в оба раздела вытаскивал утверждённый документ из канонической папки в корень другого раздела. Статус approved сохранялся, а документ исчезал из опубликованной папки — инвариант «папка зоны = документы зоны» ломался обходным путём. Спринт 5 дублирует зонную проверку: перенос в другой раздел документов из SHARED/PUBLISHED/ARCHIVE запрещён с тем же текстом ошибки, что и при DnD.

5.2. Жизненный цикл: честный мини-FSM и его хвосты

Внутренний WIP-статус — образец: декларативные спецификации действий `INTERNAL_ACTION_SPECS`, проверка исходного статуса и прав, блокировка перевода при открытых замечаниях, приём только белых значений. Матрица статусов замечаний по ролям тоже строга: закрытые переоткрывает только ГИП/админ, исполнителю ограничен переход из «Выполнено». Но у статуса документа нет единого автомата: он меняется в трёх независимых местах (DnD по зоне, workflow, загрузка), а явной матрицы переходов в коде нет — неявную задаёт маппинг зон. Обратного действия из «Опубликовано» не существует: ошибочная публикация необратима без правки БД. Рекомендация — декларативная таблица переходов с ролями и действием «распубликовать» для админа (бэклог).

Копия документа рассинхронизировала статус-триплет: копировался статус, но не suitability_code и не internal_status — копия утверждённого документа попадала в рабочую папку со статусом approved и ломала сегмент-контрол зон. Спринт 5 пересчитывает триплет по целевой папке так же, как это делает

загрузка. Корзина: очистка удаляла физические файлы до транзакции БД — падение БД оставляло записи без файлов, а маркапы замечаний вообще не удалялись и накапливались в issues/crops/. Спринт 5 переносит удаление файлов в `transaction.on_commit` и чистит маркапы. Мягкое удаление и восстановление папок при этом реализованы корректно и атомарно.

5.3. Фильтры, представления и данные

SQL-инъекций нет: ни одного сырого .raw/.extra/execute, колоночные фильтры строятся через django-filter с белым списком ключей и строгой нормализацией JSON сохраняемых видов. Найденное расхождение: сохранённый вид применял к JSON-списку документов только 5 из 7 фильтров — suitability_code и internal_status доходили лишь до таблицы, поэтому список и таблица могли показывать разное при одном виде. Спринт 5 подключает оба фильтра к queryset-сервису и добавляет тест на оба. Из низких находок: несимметричная валидация значений фильтров (некорректный код пригодности тихо даёт неотфильтрованный список), гонка дубликатов SavedView без UniqueConstraint, пересчёт ГОСТ-шифров по одному save() вне транзакции, нештатная корневая папка с именем «01. В работе» распознаётся как каноническая зона по строке имени. Последняя — самая коварная из низких: рекомендована идентификация зоны по полю, а не по названию (бэклог).

#	Находка	Severity	Статус
Л1	Обход зон через move_document_to_section	высоко	закрыто (Спринт 5)
Л2	Копия: рассинхрон статус-триплета	средне	закрыто (Спринт 5)
Л3	empty_trash: файлы до транзакции + мусор маркапов	средне	закрыто (Спринт 5)
Л4	SavedView: 2 из 7 фильтров не доходят до списка	средне	закрыто (Спринт 5)
Л5	Проверяющий с ролью viewer проходит workflow-проверку	низко	закрыто (Спринт 5)
Л6	N+1 в реестре: сотни запросов на страницу	высоко	бэклог: аннотация Count
Л7	Нет FSM и выхода из «Опубликовано»	средне	бэклог: таблица переходов
Л8	Проект удаляется безвозвратно	средне	бэклог: restore-сервис
Л9	Зона распознаётся по имени папки	средне	бэклог: поле вместо строки
Л10	ГОСТ-коды пересчитываются вне atomic	средне	бэклог: bulk_update

Таблица 4 — Ключевые находки логики (полный список — в патчах)

6. UI/UX: дизайн, юзабельность, нативность

6.1. Дизайн-система: конвейер здоров, партнёрские файлы — нет

Ядро дизайн-системы образцовое: 140 листов токенов (69 цвета, 23 типографики, 10 отступов и другие), автогенерация tokens.css, design-tokens.js и design_colors.py из одного источника, проверка дрейфа в CI, правило «статус = иконка + текст, не только цвет», prefers-reduced-motion. Но вокруг ядра живут два файла, игнорирующих его: app.css определяет собственные переменные с tailwind-синим #2563eb и содержит 178 сырых hex против 7 var(), а viewer.css дублирует значения токенов литералами. Кислотный синий, который мы вытравливали из кнопок, остался на ключевом экране: CTA пустого состояния «Загрузить первый документ» красился #3b82f6. Спринт 6 заменяет 22 кислотных значения в app.css и 3 в viewer.css на var(--c-accent) и производные; полная миграция остатков — в бэклоге с предложением линтера raw-hex в CI.

6.2. Контрастность: две пары не дотягивали до AA

Посчитанные по WCAG контрасты главного экрана: текст хедера 8.62:1 (отлично), крошки 4.72:1 (AA проходит), но muted-текст #9C9C94 на фоне приложения давал 2.55:1 — подсказки онбординга почти не читались, а рамки ghost-кнопок хедера #4B5563 на #3A4558 давали 1.28:1 при требуемых для границ контролов 3:1. Спринт 6 поднимает muted до #71716A (4.54:1) и рамку до #8A93A6 (3.13:1) через tokens.json с регенерацией всех файлов — контраст починен в одном месте и разъехался по всей системе автоматически. Заодно возвращено фокус-кольцо в поиске хедера: его перебивал локальный box-shadow:none.

6.3. Юзабельность: два критичных пробела ядра загрузки

Главный сценарий СЭД — загрузка документа — оказался невидим для пользователя. Во-первых, JS писал прогресс в #uploadStatus, но такого элемента не было ни в одном шаблоне: «Загрузка 3 файлов…» молча терялась, ошибки всплывали только тостом. Во-вторых, в тулбаре реестра не было видимой кнопки загрузки — файл можно было внести только перетаскиванием или правым кликом по папке, что неочевидно и недоступно с клавиатуры. Спринт 6 возвращает в тулбар кнопку «Загрузить» (id uploadBtn), живой статус с aria-live и спиннер HTMX-запросов; кнопка использует тот же pipeline, что и DnD. Вторая критичная пара: общие блоки (тост DnD, меню строки, модалка перемещения) рендерились внутри цикла разделов — по экземпляру на каждый раздел, то есть дублирующиеся ID, из-за которых getElementById всегда берёт первый экземпляр; теперь они вынесены из цикла. И третья: ошибки HTMX (фильтры, поиск) молчали при сетевом сбое — добавлены обработчики responseError/sendError с тостами.

6.4. Нативность и доступность

Действия с папками были доступны только через правый клик (долгий тап на таче), без Escape и фокус-менеджмента — Спринт 6 добавляет видимую кнопку кебаб в каждой строке папки (появляется на hover и фокусе), открывающую то же меню, плюс закрытие по Escape. Во вьювере кнопки «Повернуть/Рука/Выделение» использовали юникод-глифы, включая APL-символ, который на части

систем даст «тофу» — заменены на bootstrap-icons; блокирующие alert() заменены тостами с role=status. Фирменные шрифты Golos Text подключались только на странице вьювера — весь интерфейс жил системным фолбэком; теперь fonts.css грузится в base.html. Добавлены skip-link «Перейти к содержимому», id=main-content, aria-label для обоих поисков. Осталось в бэклоге: тёмная тема описана в токенах, но переключателя нет; мобильная раскладка <820px не перестраивается; таблица 12px с кнопками 26×26 меньше тач-минимума.

Пара	Было	Стало	Требование WCAG
Muted-текст на фоне приложения	2.55:1	4.54:1	4.5:1 (AA, обычный текст)
Рамки контролов хедера	1.28:1	3.13:1	3:1 (AA, границы)
Крошки на хедере	4.72:1	4.72:1	4.5:1 — проходит
Основной текст на хедере	8.62:1	8.62:1	4.5:1 — отлично

Таблица 5 — Контрастность до и после Спринта 6

7. Подсказки, тексты и покрытие тестами

7.1. Подсказки и комментарии

T69 добавил тултипы ко всем ключевым элементам — это правильное направление, но реализованы они нативным атрибутом title: такие подсказки не видны с клавиатуры и тача, не стилизуются, показываются с задержкой ОС. Для rich-подсказок вроде формата шифра это теряет смысл; в бэклоге — делегированная инициализация bootstrap.Tooltip. Сильные места: help-тексты в формах честные (формат шифра, правила папок), подсказка DnD в тулбаре есть, статусные бейджи имеют тултипы-счётчики, empty state реестра документов — эталонный (иконка, заголовок, подсказка, CTA), поиск и корзина различают «пусто» и «не найдено». Слабые: пустые состояния списка проектов, участников и корзины — голый серый текст без CTA; в тултипе реестра замечаний сырые коды статусов «NEW + IN_PROGRESS + …» вместо русских названий. Тексты: «файл(ов)» заменено плюрализацией (1 файл, 2 файла, 5 файлов), «РАЗДЕЛЫ» капсом — к токен-правилу «лейблы без CAPS», слово «маркапы» — осознанный жаргон команды, оставлен.

7.2. Тесты: 12 падений и что за ними стояло

На af4a72d падали 12 из 303 тестов. Четыре ошибки — это попытка сохранить вид с колонкой status, которую T67 переименовала в suitability и internal_status: тесты не знали о переименовании. Четыре отказа — старые ассерты разметки: filter-panel, которую заменили колоночные фильтры, id uploadBtn, которого больше нет, data-folder-menu, заменённый на data-tree-context. И четыре падения документировали реальную UX-регрессию: предупреждение о числе файлов при удалении папки исчезло из кода вместе с атрибутом data-file-count. Диагноз процессный: перед push тесты не прогонялись. Спринт 5 актуализирует все 12 под новый контракт и добавляет 18 тестов на новые защиты (зоны, матрица ответов, валидация загрузок, синхрон копии, гейт share, пароли, очистка маркапов); Спринт 6 добавляет 5

тестов на новую разметку. Итог: 326 тестов, все зелёные; конфигурация fail-closed проверена запуском.

Пробелы покрытия, которые стоит закрыть следующими: нет тестов на аудит-след (его пока нет вообще), на срок жизни и отзыв share-токенов, на производительность реестра (N+1), на контраст и на повторяемую сборку токенов из CI команды. Хорошая новость: makemigrations --check чистый, модели и миграции согласованы, конфликтов нет.

Группа	Падений	Причина	Решение
Колонки вида	4 ошибки	колонка status переименована в suitability/internal_status	тесты актуализированы
Старая разметка	4 отказа	filter-panel, uploadBtn, data-folder-menu ушли из шаблонов	ассерты переведены на новый контракт
UX-регрессия	2 отказа	data-file-count (число файлов при удалении) удалён из кода	контракт data-delete-count, текст в app.js улучшен
Счётчики колонок	2 отказа	колонок стало 11 вместо 8	ожидания обновлены

Таблица 6 — Анатомия 12 падающих тестов на af4a72d

8. Соответствие требованиям к продукту

Среда общих данных для проектной организации — это прежде всего управляемый жизненный цикл документации по ISO 19650 и ГОСТ Р 21.101. По этому критерию картина двухцветная. Светлое: версии документов создаются под select_for_update (гонки исключены), зоны WIP/SHARED/PUBLISHED/ARCHIVE с матрицей ролей и запретом обходных путей, коды пригодности S0–A синхронизированы с зонами, структура ИРД/РИИ/ПД/РД с полными шифрами по ГОСТ, замечания с ролевой матрицей и уведомлениями, мягкое удаление с корзиной и восстановлением. Тёмное: журнал действий отсутствует — кто переместил, удалил, очистил корзину, создал share-ссылку или поменял роль участника, система не фиксирует нигде; для СЭД, претендующей на работу с коммерческой тайной и экспертизой, это главное несоответствие профилю продукта.

Рекомендуемая реализация аудит-следа (первый пункт следующего спринта): модель AuditLog (actor, action, object_type, object_id, project, ip, details-json, created_at), запись в сервисном слое на восьми операциях — upload, move, delete, restore, empty_trash, share_create, download, membership_change — плюс конфиг LOGGING и экран «Журнал событий» для админа компании. Оценка — 2–3 дня. Второе несоответствие — необратимость удаления проекта: мягкое удаление есть, а сервиса восстановления нет (только ручная правка через Django admin). Третье — вечные share-токены без отзыва: для внешнего обмена по ISO 19650 нужны срок действия и отзыв владельцем. Всё остальное — электронная подпись, интеграция с экспертизой, шаблоны писем — выходит за рамки текущего скоупа и фиксировано как направление развития.

Требование СЭД	Статус	Комментарий
Версионирование без гонок	есть	select_for_update, единственная точка upload_document

Требование СЭД	Статус	Комментарий
Зоны ISO 19650 с ролями	есть	дыра обхода через раздел закрыта Спринтом 5
Структура по ГОСТ Р 21.101	есть	ИРД/РИИ/ПД/РД, полные шифры, шаблоны
Замечания с ролевой матрицей	есть	переоткрытие только ГИП/админ
Аудит-след (журнал действий)	нет	первый пункт следующего спринта
Обратимость удаления проекта	частично	мягкое удаление есть, restore-сервиса нет
Контролируемый внешний обмен	частично	share-токены вечные, без отзыва

Таблица 7 — Профиль СЭД: соответствие требованиям

9. Спринты 5–6: состав поставки

К отчёту приложены два патча, построенные на базе af4a72d (текущий origin/main). «Спринт 5 · надёжность и безопасность» — серверные исправления и починка тестовой базы: зоны при переносе в раздел, матрица прав на ответ замечания, валидация загрузок (25 форматов, 100 МБ), fail-closed настройки, парольная политика, гейт замечаний share-ссылки, on_commit в очистке корзины с чисткой маркапов, синхронизация триплета копии, оба колоночных фильтра в сохранённых видах, безопасные имена скачивания, актуализация 12 устаревших тестов и 18 новых. «Спринт 6 · UX-полировка» — интерфейс: видимая кнопка «Загрузить» со статусом и спиннером, тосты ошибок HTMX, кебаб-меню папок с Escape, tokens.css и шрифты на странице входа, контраст-фиксы через токены, вытравка 22+3 кислотных значений, skip-link и aria-атрибуты, иконки и тосты во вьювере, плюрализация текстов. После применения обоих спринтов: 326 из 326 тестов зелёные, manage.py check чистый, drift-check токенов проходит.

Файл	Содержимое
sod_sprint5.patch	патч 17 файлов: services, views, settings, 6 тестовых файлов + test_sprint5.py
sod_sprint6.patch	патч 11 файлов: шаблоны, app.js, pdf_viewer.js, 3 CSS, токены + тесты
файлы/	полные версии изменённых файлов (включая бинарники и сгенерированные токены)
скриншоты/	вход, дашборд, реестр с кнопкой «Загрузить», дерево с кебабом, вьювер
README_AUDIT4.md	порядок установки, проверка (326 тестов), откат

Таблица 8 — Состав поставки генерального аудита

Порядок установки: применить sod_sprint5.patch на чистой af4a72d (git apply --check для пробы, затем git apply), при наличии конфликтов — взять полные файлы из папки файлы/; затем sod_sprint6.patch тем же способом; выполнить python manage.py test — ожидается 326 из 326; перезапустить сервер. Миграций база данных не требует — структурные изменения только в статики и Python-код. Откат — git checkout af4a72d. Патчи независимы от Спринта 3: зачистку 5657388, если она ещё не применена у вас локально, можно накатить после — конфликтов по файлам нет.

10. Бэклог и рекомендации

Остаток находок выстроен по влиянию на продукт. Первый эшелон (следующий спринт, 3–4 дня): аудит-след с моделью AuditLog и экраном журнала для админа; N+1 в реестре документов — аннотировать счётчик открытых замечаний и кэшировать кнопки workflow на запрос (реестр — самый горячий экран); share-токены — срок жизни, отзыв владельцем и перевод создания на POST; сужение делегирования «Управление участниками» от ГИПа к админу. Второй эшелон (спринт после): декларативный FSM статусов документа с действием «распубликовать»; restore-сервис для проектов; идентификация зон по полю, а не по имени папки; bootstrap.Tooltip для тултипов; пустые состояния проектов/участников/корзины по образцу реестра документов.

Третий эшелон (по мере сил): полная миграция app.css и viewer.css на токены с линтером raw-hex в CI; dark-тема — переключатель data-theme уже описан токенами; мобильная раскладка <820px; UniqueConstraint для SavedView; GROUP BY вместо Python-пересчёта счётчиков зон; потоковый ZIP вместо BytesIO; пересмотр company-wide чтения для viewer/customer — это продуктовое решение, которое стоит принять осознанно и записать в спецификацию. Отдельная процессная рекомендация: прогон тестов перед каждым push (326 тестов занимают пять минут) и правило «переименовал разметку — обнови ассерты тем же коммитом». Дисциплина тестов — единственное, что в этом цикле отставало от качества кода.

Спасибо команде за темп и за то, что дизайн-система выдержала первый цикл развития без аудитора. Следующая проверка рекомендована после закрытия аудит-следа и N+1 — на ней же сверим, что бэклог второго эшелона не оброс новыми регрессиями.